# CYS 410: SECURITY AND RISK MANAGEMENT PRACTICES

MS. NANYANGWE L.R

nanyangweleah@gmail.com

0967203891 (WHATSAPP)

# 13. TOOLS AND TYPES OF RISK ASSESSMENT

- Qualitative vs. quantitative risk analysis
- Security assessment tools (e.g., Nmap, Wireshark, Nessus)
- Business impact analysis (BIA)

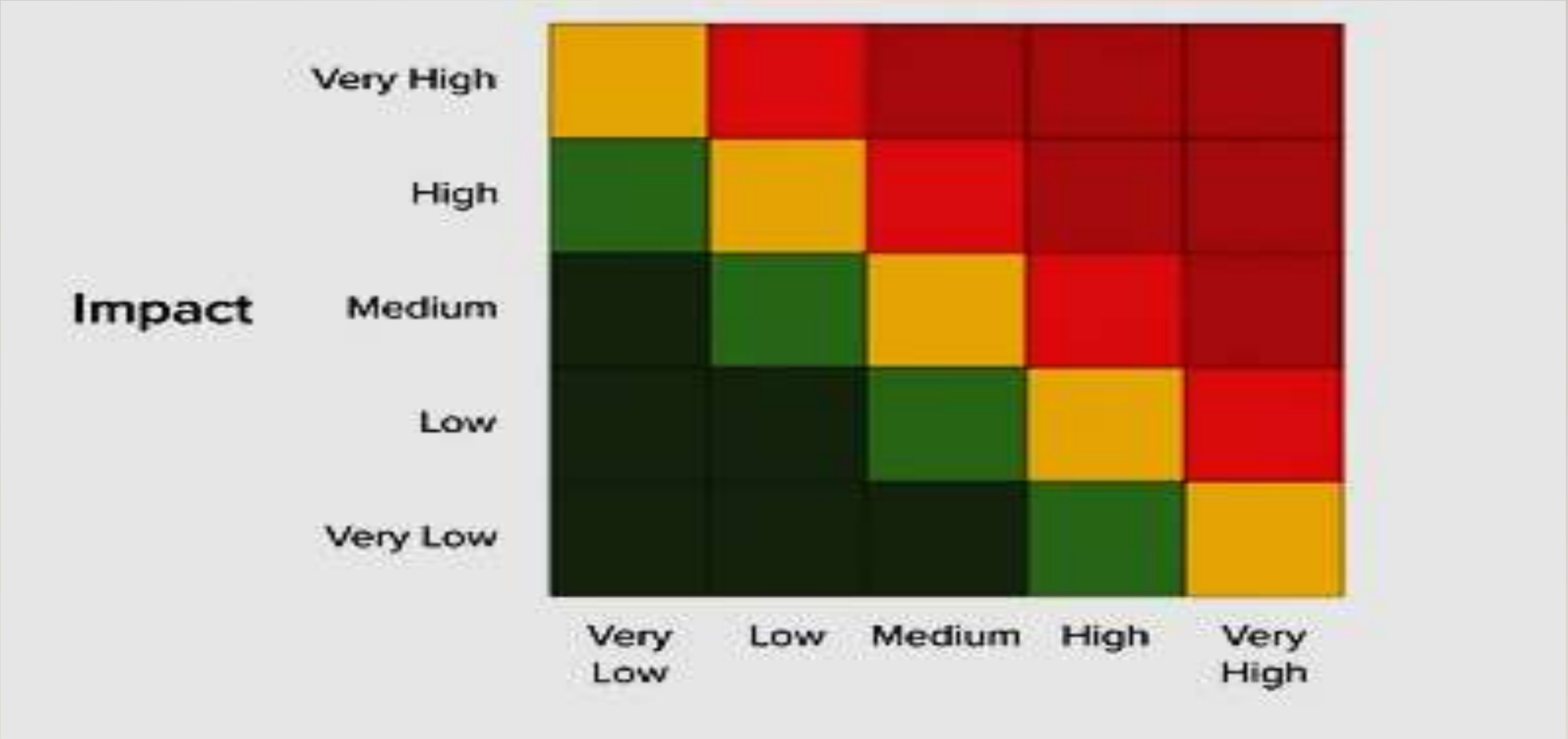
# INTRODUCTION

- Risk assessment is a critical component of security management, There are various tools and approaches used for risk assessment, helping organizations to:
  - Identify potential risks and understand their impacts.
  - Make informed decisions about risk mitigation and response strategies.

# QUALITATIVE VS. QUANTITATIVE RISK ANALYSIS

- Risk analysis can be conducted in two primary ways:
  - qualitative risk analysis
  - Quantitative risk analysis
- Both approaches aim to assess the likelihood and impact of risks but differ in how they approach data collection, analysis, and decision-making.

# QUALITATIVE RISK ANALYSIS



# QUANTITATIVE RISK ANALYSIS



# QUALITATIVE RISK ANALYSIS

- Qualitative analysis focuses on assessing risks based on subjective judgment, experience and non-numerical data.
- This method is typically used when precise quantitative data is unavailable or difficult to obtain.

# QUALITATIVE RISK ANALYSIS…

- **Example**:
  - A small IT firm may perform a qualitative analysis to assess the likelihood of data breaches based on its history and industry knowledge.

# COMMON TECHNIQUES USED IN QUALITATIVE RISK ANALYSIS

1. **Risk Matrix or Heatmap**: Risks are assessed using a matrix that evaluates both the probability of occurrence and the severity of the impact.
2. **Expert Judgment**: Relying on the expertise of stakeholders or risk management professionals to evaluate risks.
3. **Scenario Analysis**: Examining potential risk scenarios and the associated consequences.

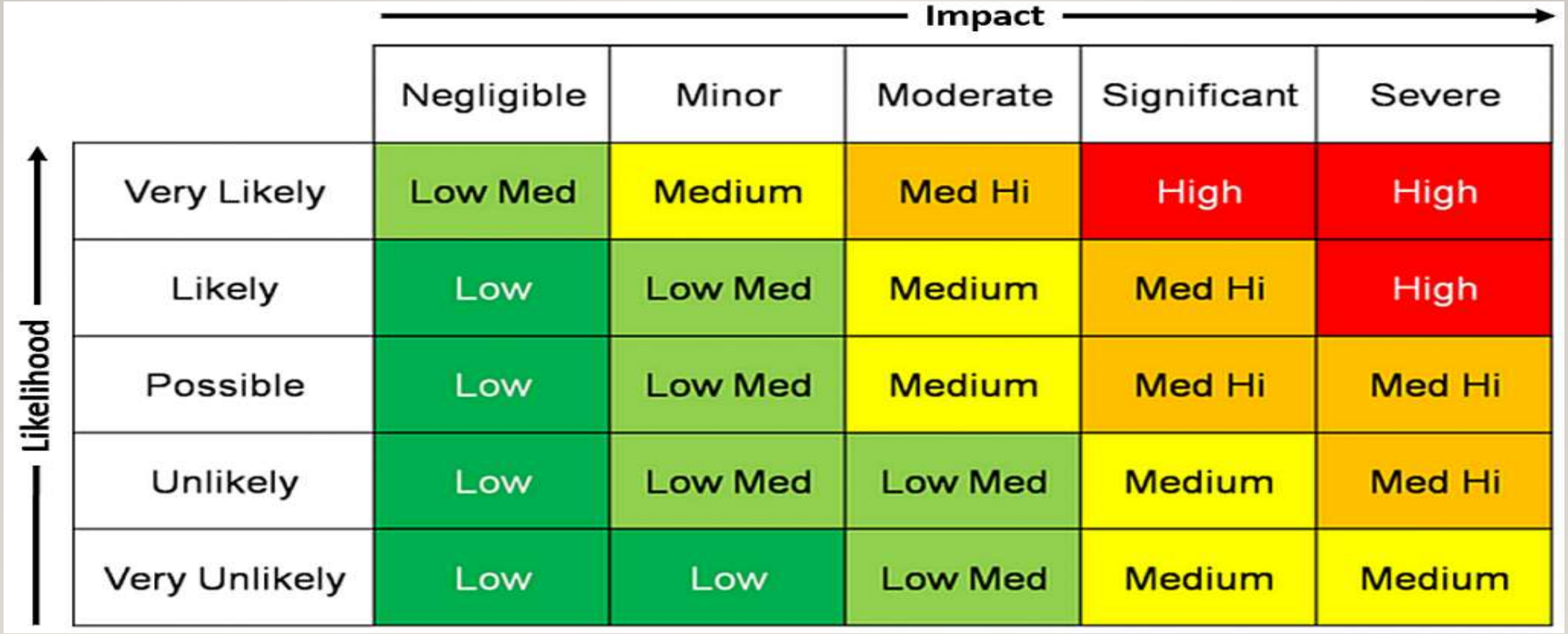
# QUALITATIVE RISK ANALYSIS APPROACH

- Risks are categorized as high, medium, or low in terms of their likelihood and impact.

# QUALITATIVE RISK ANALYSIS METHOD

- Risks are ranked by their impact (severity) and likelihood, often using categories like “low,” “medium,” and “high.”
- A risk matrix or heatmap is often used to visualize these evaluations.

# RISK MATRIX EXAMPLE




| | Negligible | Minor | Moderate | Significant | Severe |
|---|---|---|---|---|---|
| Very Likely | Low Med | Medium | Med Hi | High | High |
| Likely | Low | Low Med | Medium | Med Hi | High |
| Possible | Low | Low Med | Medium | Med Hi | Med Hi |
| Unlikely | Low | Low Med | Low Med | Medium | Med Hi |
| Very Unlikely | Low | Low | Low Med | Medium | Medium |

# ADVANTAGES OF QUALITATIVE ANALYSIS

- Simple and quick to perform.
- Helps prioritize risks without needing extensive data.
- Useful for early-stage risk assessments when more detailed data is not yet available.
- Easy to understand.

# DISADVANTAGES OF QUALITATIVE ANALYSIS

- Highly subjective and may vary depending on individual experience.
- May not provide precise information needed for complex risk decisions.
- Can be less accurate and more prone to bias.

# QUANTITATIVE RISK ANALYSIS

- This approach uses numerical data and statistical methods to assess the impact and likelihood of risks.
- Typically used when there is a need for precise, measurable results to justify risk management decisions.

# QUANTITATIVE RISK ANALYSIS…

- **Example**:
  - A large corporation might use quantitative analysis to assess the financial impact of a cyberattack based on past breaches in the industry.

# COMMON TECHNIQUES USED QUANTITATIVE RISK ANALYSIS

- **Probability Analysis**: Calculating the likelihood of specific risks occurring and their impact on operations or finances.
- **Value at Risk (VaR)**: A financial risk measure that quantifies the potential loss in value of an asset or investment.

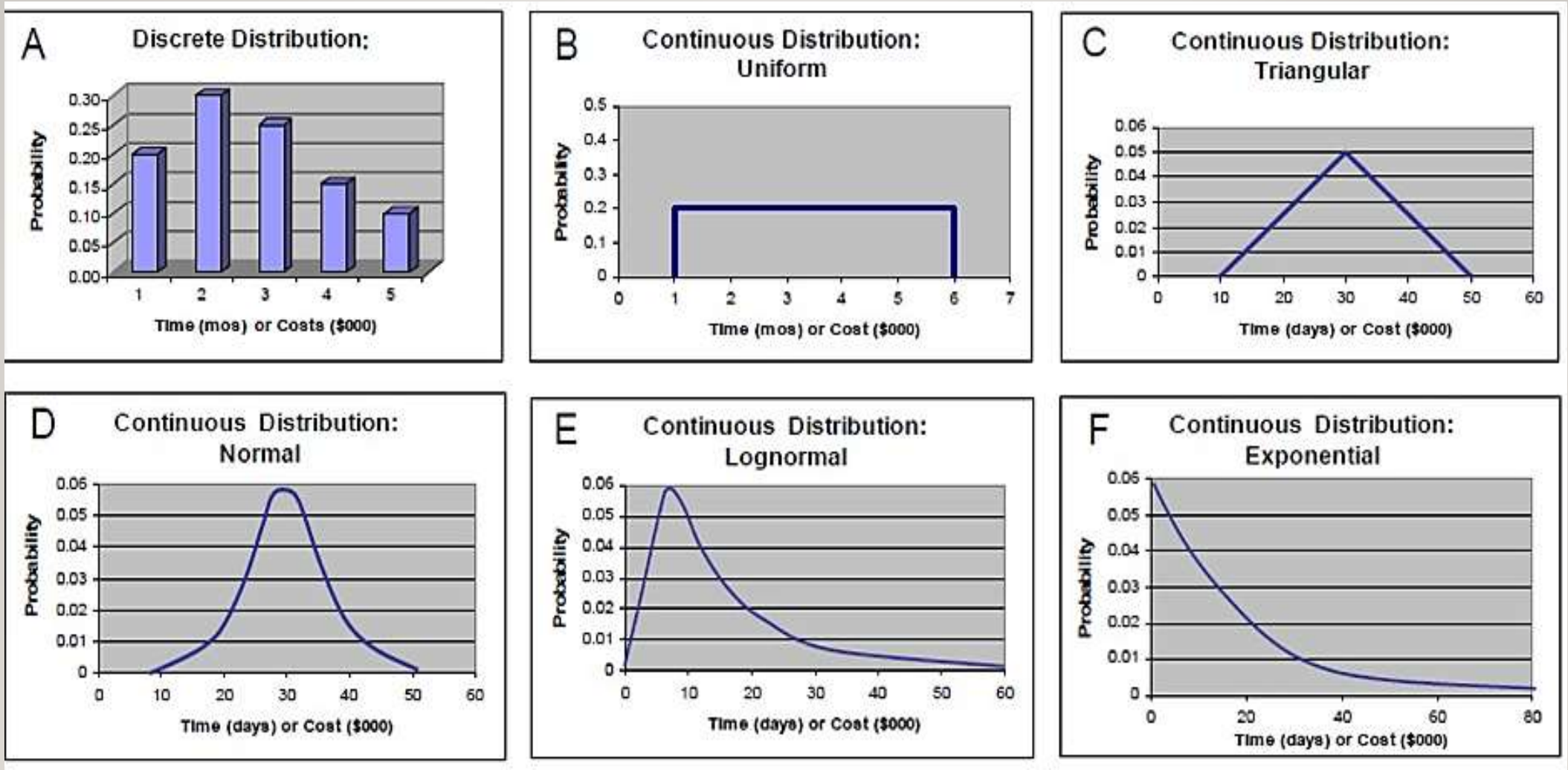
# QUANTITATIVE RISK ANALYSIS APPROACH

- Risks are analysed using measurable data, such as probabilities, financial values, and other numerical metrics.

# QUANTITATIVE RISK ANALYSIS METHOD

- Data such as financial losses, probability distributions, and historical incident data are used to quantify risks.

# PROBABILITY ANALYSIS



# PROBABILITY ANALYSIS…

RISK OUTCOME
Low
Moderate
Significant
High

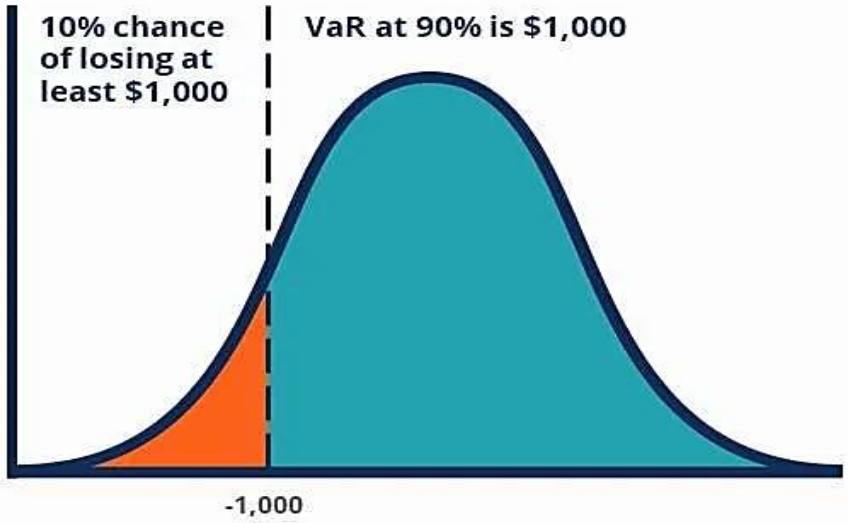
| Likelihood | Consequence | | | | |
|---|---|---|---|---|---|
| | Insignificant 1 | Minor 2 | Moderate 3 | Major 4 | Catastrophic 5 |
| Almost Certain 5 | 5 | 10 | 15 | 20 | 25 |
| Likely 4 | 4 | 8 | 12 | 16 | 20 |
| Possible 3 | 3 | 6 | 9 | 12 | 15 |
| Unlikely 2 | 2 | 4 | 6 | 8 | 10 |
| Rare 1 | 1 | 2 | 3 | 4 | 5 |

# VALUE AT RISK (VAR)

## Value At Risk

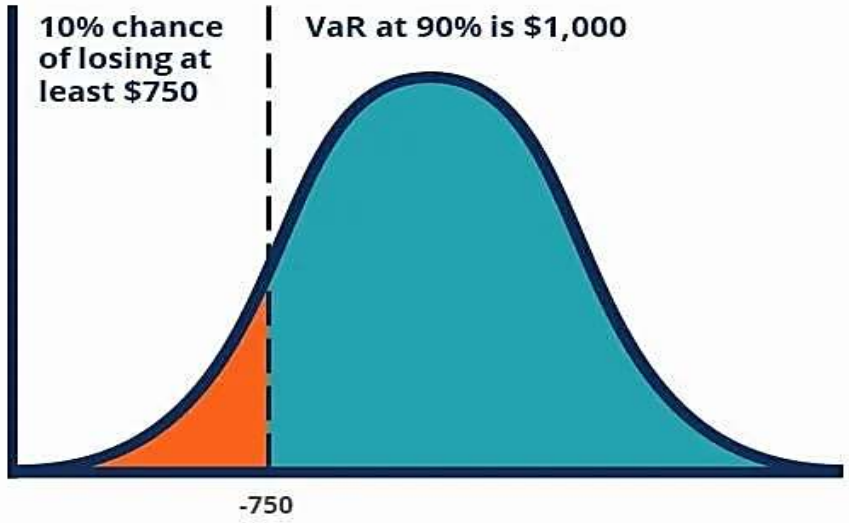
**Project A**

Expected Profit: $10,000




**Project B**

Expected Profit: $10,000



# ADVANTAGES OF QUANTITATIVE RISK ANALYSIS

- Provides objective, data-driven results.
- Can model complex risk scenarios with precision.
- Helps in making more informed financial decisions regarding risk.
- Is more precise and offers concrete numbers for decision-making.

# DISADVANTAGES OF QUANTITATIVE RISK ANALYSIS

- Requires access to extensive and accurate data.
- Time-consuming and may require specialized tools or expertise.
- May be too complex for smaller or less data-intensive organizations.

# SECURITY ASSESSMENT TOOLS

- Security assessment tools are essential for identifying vulnerabilities, misconfigurations, and potential risks in an organization's IT infrastructure.
- These tools can help with identifying threats, testing system resilience, and performing security audits.
  - This can be done by performing tasks such as network scanning, vulnerability assessment, and network traffic analysis.

# COMMON SECURITY ASSESSMENT TOOLS

- **Nmap (Network Mapper)**
- **Wireshark**
- **Nessus**
- **OpenVAS**
- **Metasploit**
- **Burp Suite**

# NMAP (NETWORK MAPPER)

- It's commonly used in penetration testing and vulnerability assessments.
- Can be used to discover devices on a network and assess their security.
- You can use Nmap to scan for unauthorized devices on a network, check for exposed ports that could be vulnerable to attacks, Identifying exposed services, scanning for vulnerabilities, and mapping network architecture.
  - **Features**:
    - Performs network discovery and security auditing.
    - Identifies open ports, services, and potential vulnerabilities in the system.
    - Can detect firewalls, routers, and other network security devices.

# WIRESHARK

- It helps in diagnosing network problems and detecting potential security threats, such as suspicious traffic or malware communication.
- Analysing traffic to detect data breaches, diagnosing network issues, and monitoring for potential security threats.
- By analysing network traffic, you can identify patterns that suggest a cyberattack or data exfiltration.
  - **Features**:
    - Provides detailed packet-level analysis.
    - Helps identify suspicious activity, performance issues, and vulnerabilities.
    - Supports a wide range of protocols for deep network inspection.

# NESSUS

- Nessus is a widely used vulnerability scanner that detects vulnerabilities within networks, systems, and applications. It generates detailed reports on the risks associated with specific vulnerabilities.
- Nessus can be used to run regular vulnerability scans, compliance audits, and identifying exploitable weaknesses in systems or web servers to identify outdated software or configuration flaws that could be exploited.
  - **Features**:
    - Scans for known vulnerabilities, including missing patches and misconfigurations.
    - Provides detailed reports on vulnerabilities with suggestions for remediation.
    - Supports scanning of various systems, including networks, web applications, and databases.

# OPENVAS

- Another open-source vulnerability scanner similar to Nessus but with additional features for broader security audits.

# METASPLOIT

- A framework for penetration testing and developing and executing exploits.

# BURP SUITE

- A popular tool for web application security testing, especially for identifying vulnerabilities like cross-site scripting (XSS) and SQL injection.

# BUSINESS IMPACT ANALYSIS (BIA)

- Business Impact Analysis (BIA) is a process used to evaluate the potential consequences of disruptions to critical business functions.
- It helps organizations identify and prioritize the most important business processes and assess the impact of risks such as cyberattacks, system outages, and natural disasters.
- It focuses on identifying the potential impacts of various risks on business operations and understanding how those impacts can affect an organization's ability to function effectively.

# STEPS IN BIA

1. **Identify Critical Business Processes**: List all business functions and determine their importance.
2. **Assess Impact**: Evaluate the financial, legal, operational, and reputational impact of disruptions to each business process.
3. **Identify Dependencies**: Identify the resources (e.g., systems, personnel, suppliers) necessary to support critical functions.

# STEPS IN BIA

4. **Define Recovery Objectives**: Determine recovery time objectives (RTO) and recovery point objectives (RPO) for each critical process.
   - **Recovery Time Objective (RTO)**: This is the maximum allowable downtime for a critical business function. The BIA helps determine how quickly processes must be restored after a disruption.
   - **Recovery Point Objective (RPO)**: The RPO refers to the point in time to which data must be restored to ensure business continuity. The BIA assesses the data loss risk and defines acceptable limits.
5. **Develop Mitigation Strategies**: Create strategies to mitigate risks and minimize the impact of disruptions, such as creating business continuity plans.

# PURPOSE OF BIA

- **Identify Critical Functions**: BIA helps determine which business functions and assets are most vital to the organization's operations and success.
- **Evaluate Impact**: It assesses the potential financial, operational, and reputational impact of disruptions to these critical functions.
- **Prioritize Risks**: BIA helps prioritize risks based on their impact on the organization's objectives and resources.

# BENEFITS OF BIA

- **Informed Decision Making**: BIA helps decision-makers understand the most important processes to prioritize during a crisis.
- **Enhanced Continuity Planning**: It plays a vital role in developing business continuity and disaster recovery plans, ensuring that essential functions can continue during or after a disruption.
- **Resource Allocation**: BIA helps allocate resources efficiently by identifying which assets need the most protection and which systems should be restored first.

# 14. THE FUTURE OF RISK MANAGEMENT

- AI and machine learning in risk management
- Zero-trust security frameworks
- Future challenges in IT risk management

# INTRODUCTION

- Risk management is continually evolving to address the dynamic threats and complexities posed by emerging technologies.
- The future of risk management involves integrating cutting-edge technologies such as AI, machine learning, and zero-trust frameworks to enhance security, streamline processes, and improve decision-making.

# AI AND MACHINE LEARNING IN RISK MANAGEMENT

- Artificial Intelligence (AI) and Machine Learning (ML) are revolutionizing risk management by enabling more proactive and automated approaches to identifying, assessing, and mitigating risks.
- These technologies can handle vast amounts of data and provide insights that were previously unattainable through traditional methods.

# APPLICATIONS OF AI AND ML IN RISK MANAGEMENT:

- **Automated Threat Detection**: AI can analyse network traffic, identify patterns, and detect anomalies that may signal a potential security threat. ML models can learn from previous attack data and continuously improve the system's ability to detect new threats.
  - *Example*: AI-driven systems can automatically detect phishing attempts by analysing email content, sender reputation, and other factors that indicate malicious intent.

# APPLICATIONS OF AI AND ML IN RISK MANAGEMENT

- **Predictive Analytics**: Machine learning models can be trained on historical data to predict future risks. By analysing trends, they can forecast potential security breaches, allowing organizations to act before incidents occur.
  - *Example*: Using data from previous cyberattacks, ML algorithms can predict the likelihood of a future attack and suggest counter measures.

# APPLICATIONS OF AI AND ML IN RISK MANAGEMENT…

- **Risk Scoring and Prioritization**: AI can assess and assign risk scores to different vulnerabilities based on their likelihood of exploitation and potential impact. This helps security teams prioritize resources effectively.
  - *Example*: An AI model could evaluate the risk level of various vulnerabilities within an organization's infrastructure and recommend which ones to address first based on severity and potential impact.

# BENEFITS OF AI AND ML IN RISK MANAGEMENT

- **Enhanced Efficiency**: AI and ML automate tedious manual tasks such as monitoring and analysis, allowing security teams to focus on strategic decision-making.
- **Real-time Threat Response**: These technologies provide faster detection and response times, reducing the time between detection and mitigation.
- **Predictive Capabilities**: The ability to forecast potential risks allows organizations to be more proactive rather than reactive.

# ZERO-TRUST SECURITY FRAMEWORKS

- Zero-trust security is a model based on the principle of "never trust, always verify." It assumes that every user, device, and system, whether inside or outside the organization, could be compromised.
- Therefore, it requires continuous verification of every access request, regardless of where it originates from.

# KEY COMPONENTS OF ZERO-TRUST SECURITY

- **Identity and Access Management (IAM)**: Ensures that only authorized users and devices can access systems and data. Access is granted based on the principle of least privilege, meaning users are only allowed to access the specific resources they need.
  - *Example*: Multi-factor authentication (MFA) is often a key component of IAM to verify users before granting access.

# KEY COMPONENTS OF ZERO-TRUST SECURITY…

- **Micro-Segmentation**: Dividing the network into smaller segments and applying strict access controls to each segment. This limits the lateral movement of attackers within the network.
  - *Example*: A user with access to the finance department's data may not automatically have access to other departments' data, reducing the risk of a compromised account leading to a widespread attack.

# KEY COMPONENTS OF ZERO-TRUST SECURITY…

- **Continuous Monitoring and Analytics**: Real-time monitoring and behavioural analytics are used to detect and respond to abnormal or suspicious activities.
  - *Example*: The system continuously checks whether the user's behaviour matches their typical usage patterns, and flags any deviation as suspicious.

# BENEFITS OF ZERO-TRUST SECURITY FRAMEWORK

- **Enhanced Security**: By not trusting any entity by default and verifying each request, the zero-trust model significantly reduces the risk of unauthorized access or insider threats.
- **Minimized Attack Surface**: Even if an attacker compromises a part of the network, they cannot easily access other parts due to micro-segmentation.
- **Flexibility and Scalability**: Zero-trust security frameworks are adaptable to a variety of environments, including cloud, on-premises, and hybrid infrastructures.

# FUTURE CHALLENGES IN IT RISK MANAGEMENT

**Emerging Threats and Evolving Attack Techniques:**

- The rapid advancement of technology brings new risks, including those related to IoT (Internet of Things), artificial intelligence, and the increasing sophistication of cyberattacks.
- Attackers are using more advanced tactics, such as AI-driven malware and social engineering, to bypass traditional security measures.

# CHALLENGES

- **Complexity of Risk Management**: As organizations adopt new technologies, the complexity of managing and securing their environments increases.
  - Ensuring that security measures evolve in parallel with technological advancements is a constant challenge.

# CHALLENGES…

- **Data Privacy Concerns**: With the growing amount of personal and sensitive data being generated and stored, protecting that data against breaches and misuse remains a top priority.
  - The challenge of complying with data privacy regulations (such as GDPR and HIPAA) while maintaining business operations can be daunting.

# CHALLENGES…

- **CoCloud and Hybrid Environments**: With the rise of cloud services and hybrid infrastructures, organizations face difficulty in managing risks across diverse environments, each with its own set of vulnerabilities.

# CHALLENGES…

- **Supply Chain Risks**: Modern businesses are more interconnected than ever before, and supply chain vulnerabilities can introduce significant risks.
  - A third-party breach can have a cascading effect on the organization.

# CHALLENGES…

- **Human Factor and Insider Threats**: Despite advancements in technology, the human element remains one of the most significant risks in IT security.
  - Insider threats, accidental mistakes, or negligence can undermine the best technical defences.

# ADDRESSING THE CHALLENGES

- **Automation and AI**: Leveraging AI and automation tools to manage and respond to risks quickly and efficiently is a key strategy in overcoming the challenges posed by complex IT environments.
- **Integrated Risk Management Solutions**: Organizations will increasingly adopt integrated risk management platforms that provide a unified view of their risks across various business functions and technologies.

# ADDRESSING THE CHALLENGES…

- **Advanced Threat Intelligence**: Proactively sharing threat intelligence and collaborating across industries can help mitigate the impact of emerging threats.